

The CISO Lens

An audience-specific reading of the OIA Reference Model for chief information security officers and the security organisations they lead.

By Mark Templeton · Part of the OIA Lens System · Version 0.5 · 2026 · Published by the Agentics Foundation

1. What this document is

The OIA Reference Model describes the structural shape of enterprise intelligent systems. It is deliberately vendor-neutral and audience-neutral — ten layers, seven cross-layer spans, three defining properties, four named threat surfaces, written so that any audience can read the same architecture without it being slanted toward any one of them.

Reference architectures in their pure form are read by very few people. Most CISOs do not work from structural specifications. They work from their own frameworks, their threat reality, the questions on their desks this quarter. Without translation, the OIA risks being filed as an architecture document that never reaches the conversations it was built to inform.

This is the translation. The CISO Lens reads the same OIA architecture through the questions a CISO is actually asking, the frameworks already in their program plans, and the threat surfaces that define what they have to defend against. The architecture is invariant. The lens changes the language.

2. What is in the CISO planning conversation in 2026

Seven observations frame what the security audience is engaging with today. The lens that follows is calibrated to them.

- **AI has changed both the speed of attack and the surface area of who can be attacked.** Email and collaboration are still the delivery layer; humans are still the primary target; but agents are now both targets and weapons, operating inside the enterprise at machine speed.
- **Three actors now require continuous trust governance.** Humans, agents, and the foundation models themselves. The third actor is new — a foundation model whose trustworthiness is dynamic, must be continuously scored against current threat reality, and cannot be assumed from procurement-time evaluation.
- **The prompt is the perimeter.** Traditional perimeters do not see inside inference calls. AI

is a permanent operating domain that requires semantic-layer controls, not just network and identity controls.

- **There is no malware to catch.** Adversaries operate with valid credentials, authorised tools, and the appearance of normal users. Detection-of-anomaly approaches built for the malware era are not sufficient for the agentic one.
- **Speed is the security control.** Every existing control must be re-validated under the question: does this still work at machine speed?
- **Frameworks are converging but not yet sufficient.** NIST CSF, NIST AI RMF, MITRE ATLAS, MITRE D3FEND, OWASP LLM Top 10, the Confidential Computing Consortium body of work — each addresses part of the picture. None addresses the architecture as a whole.
- **AI has become a board-level accountability concern.** CISOs are increasingly asked to brief boards and audit committees on AI risk in language those audiences can audit. The OIA's layer-and-span vocabulary is built for that translation.

3. The seven interpretive lenses on three axes

The CISO Lens organises the way security teams think about AI as a category through seven interpretive lenses on three orthogonal axes. The lenses are not new framings the CISO must learn; they are existing framings the CISO is already using, named and anchored to existing frameworks.

Threat axis · How AI threatens

AI as Amplifier. *Speed is the security control.* Every existing control must be re-validated under the question of whether it still works at machine speed. Anchor: **NIST CSF**.

AI as Domain. *The prompt is the perimeter.* Traditional perimeters do not see inside inference calls; AI is a permanent operating domain requiring semantic-layer controls. Anchor: **NIST AI RMF**.

AI as Attacker. *There is no malware to catch.* Adversaries operate with valid credentials, authorised tools, and the appearance of normal users; resilience is the primary defence. Anchor: **MITRE ATLAS**.

Operational axis · How AI integrates

AI as Defender. *The defender has the same superpower as the attacker.* If adversaries operate at machine speed, defence must too — AI-augmented SOC operations are no longer optional. Anchor: **MITRE D3FEND**.

AI as Asset. *Your AI is a crown-jewel asset.* Models, fine-tunes, prompts, and training data are business-critical IP — protect them like source code, not like tools. Anchor: **NIST CSF (Identify + Protect).**

AI as Workforce. *Every agent is an employee with elevated privileges.* Govern them like one — onboarding, role-based access, behavioural baselines, off-boarding, segregation of duties. Anchor: **NIST CSF (Govern + Protect).**

Foundational axis · How AI's trust model works

AI as Trustless. *Trust is verified, not granted.* Confidential computing makes operations trustless rather than trust-dependent — hardware attestation (Intel TDX, NVIDIA Confidential GPU, AMD SEV-SNP) replaces vendor promises with cryptographic proof. The operator no longer needs to be trusted to see inside the workload. Anchor: **Confidential Computing Consortium.**

4. The four failure modes a CISO must be able to answer affirmatively for

The OIA names four threat surfaces of the agentic era as canonical inside the architecture. For each, the CISO Lens phrases the question in the form security audiences voice it in their planning conversations.

Mimicry — AI as Attacker

“Can we tell humans from agents — and AI from real humans — at every entry point?”

Origin Layer 9, propagation through Layer 7, landing at Layer 3 as persisted state. Framework anchors: NIST CSF, MITRE ATLAS. Defence concentrates on interface-level liveness, content provenance, and identity discrimination at the human-system boundary.

Agent-in-the-middle — AI as Domain

“Can we trust the chain between every agent and every tool — including MCP servers — at machine speed?”

Origin and primary domain at Layer 7. Framework anchors: MITRE ATLAS, Identity span. Defence concentrates on tool registry integrity, vetted tool calls, and gateway architecture for MCP and adjacent protocols.

Agent spoofing — the OIA's open question

“Are agent identities scoped, attestable, and prevented from inheriting trust they shouldn't have?”

Spans Layers 5 through 9, with concentration at Layer 7. Framework anchors: NIST AI RMF, Identity span. Defence concentrates on agent identity governance — onboarding, scope assignment, behavioural baselining, offboarding — alongside conventional identity infrastructure.

This is the architectural problem the existing identity infrastructure was not designed to solve.

Model compromise — AI as Domain + Attacker

“Are we continuously scoring the trustworthiness of every model we use, against current threat reality?”

Origin at Layer 5. Framework anchors: OWASP LLM Top 10, Security span. Defence concentrates on continuous model trust scoring, attested inference, and the recognition of foundation models as actors whose trustworthiness is dynamic and must be governed dynamically.

5. The ten layers through the CISO Lens

The CISO Lens reads each OIA layer through the question a CISO is actually asking, the risks at that layer, and the framework references that already live in their program plans. The complete table is in the companion one-page architecture map; the narrative summary follows.

Layer 9 • Human and Browser Interface

Question: “Can we tell humans from agents at every entry point — and is our deepfake defence keeping up?”

Frameworks: NIST CSF (Protect / Detect), MITRE ATLAS, MITRE D3FEND.

Maturity (typical enterprise): Partial. Identity discrimination is mature; mimicry defence at consumer scale is build-out.

Layer 8 • Continuity Fabric

Question: “How do we recover when an autonomous agent has mis-acted, and the audit chain is broken because the model that decided is no longer the model deployed?”

Frameworks: NIST AI RMF (Manage), Auditability and Verifiability spans.

Maturity (typical enterprise): Build-out. The architecturally consequential gap in the present technology stack.

Layer 7 • Orchestration and Workflow

Question: “Are agent identities scoped, attestable, and prevented from inheriting trust they shouldn’t have? Are tool calls vetted at machine speed, including MCP servers?”

Frameworks: MITRE ATLAS, NIST AI RMF, Identity span.

Maturity (typical enterprise): Build-out. Agent identity governance is a category-of-one open question.

Layer 6 • Context and Knowledge

Question: “Can adversaries poison our retrieval or context to compromise model output?”

Frameworks: OWASP LLM Top 10 (LLM01, LLM03), MITRE ATLAS.

Maturity (typical enterprise): Partial. Prompt injection defence at production scale is build-out.

Layer 5 • Inference and Retrieval

Question: “Are we continuously scoring the trustworthiness of every model we use against the threat reality of this week, not last quarter?”

Frameworks: OWASP LLM Top 10, NIST AI RMF, Verifiability span.

Maturity (typical enterprise): Build-out. Continuous model trust scoring as a discipline is in early enterprise deployment.

Layer 4 • Model Training and Adaptation

Question: “Can fine-tuning happen inside an attested confidential boundary for regulated data?”

Frameworks: NIST AI RMF (Govern), Confidential Computing Consortium, Provenance span.

Maturity (typical enterprise): Partial. Attested fine-tuning is technically possible; enterprise-scale deployment is build-out.

Layer 3 • Agent Data Substrate

Question: “What sensitive data is reaching LLM APIs via embedded SaaS — the AI-Inside problem — and are we governing it the way we govern intentional LLM use?”

Frameworks: NIST CSF (Protect / Detect), Auditability and Provenance spans.

Maturity (typical enterprise): Strong on traditional DLP; partial on AI-Inside detection; build-out on agent-aware data governance.

Layer 2 • Sovereign Infrastructure

Question: “Where can regulated AI workloads physically run, and can the operator be cryptographically attested rather than contractually trusted?”

Frameworks: ISO/IEC 42001, Sovereignty and Verifiability spans, CCC.

Maturity (typical enterprise): Partial. Sovereign cloud regions exist; attested compute at scale is build-out.

Layer 1 • Silicon Abstraction

Question: “Are we using the hardware-attested execution primitives — Intel TDX, AMD SEV-SNP, NVIDIA Confidential GPU — that anchor verifiability at the foundation of the stack?”

Frameworks: Confidential Computing Consortium, Verifiability span.

Maturity (typical enterprise): Build-out. The primitives exist; enterprise deployment is early.

Layer 0 • Physical Compute

Question: “Where do our AI workloads physically run, and what is our exposure if a sovereign or supply-chain event interrupted that?”

Frameworks: Sovereignty span, Energy span, supply chain risk governance.

Maturity (typical enterprise): Partial. Geographic siting is increasingly addressed; energy sovereignty is build-out.

6. Adopting the lens

The CISO Lens is published as a Foundation reference. Three uses are anticipated.

- **As a planning lens for the security organisation.** The ten layers and seven spans provide a structural map for organising AI security priorities, coverage assessment, and gap analysis. The CISO Lens translates the architecture into language the security organisation already uses.
- **As a translation surface for board and executive engagement.** When the security organisation briefs the audit committee, the board, or the chief executive on AI risk, the CISO Lens makes the architecture legible to those audiences while preserving the structural rigour the security organisation needs.
- **As a vendor-neutral evaluation vocabulary.** When evaluating AI security vendors and platforms, the CISO Lens provides a structural map against which coverage claims can be located — vendors describe their work in OIA layer-and-span vocabulary, and gaps become visible at the architectural level rather than the feature level.

The Foundation invites the security community to engage with the lens, push back on what does not fit, and contribute to its continued refinement. The architecture will continue to develop. The CISO Lens will develop with it.